MALAYSIAN INSTITUTE OF INFORMATION TECHNOLOGY

UNIVERSITI KUALA LUMPUR

BACHELOR OF INFORMATION TECHNOLOGY (HONS) IN COMPUTER SYSTEM SECURITY

FINAL YEAR PROJECT (FYP) PROPOSAL

TITLE: Spectra Chat: Quantum-Safe Messaging with Blockchain & ZKP

PREPARED BY:

NAME : MOHAMMAD AZRI BIN AZIZ

ID. NUMBER : 52215123264

For Office Use Only		
1.	Evaluator's Comment:	☐ Accept ☐ Reject
2.	Comments/ Remarks	
3.	Checked & Verified by: ..... Name: Designation: Date:	Approved/Not Approved by: ..... Name: Designation: Date:

DETAILS OF THE STUDENT

Name	
ID. Number	
Semester	
CGPA	
Handphone Number	
Email Address	
Potential Supervisor	
Signature & Stamped	

Table of Contents

Page No.

1. Background of Study 3
2. Problem Statement 5
3. Objective 6
4. Scope 7
5. Significance of the Project 8
6. Literature Review 0
7. Methodology 0
Conclusion 3
References 4

1. Background of Study

Secure internal communication is a core requirement for modern corporations, where sensitive business data, legal discussions, and regulated information are exchanged daily. Existing enterprise messaging solutions often rely on personal identifiers (phone numbers, email addresses) for authentication and on classical public-key cryptography for message protection. These design choices expose organisations to two intersecting risks: (1) privacy and compliance exposure from stored identifiers and message-related metadata, and (2) long-term confidentiality risk posed by the future arrival of large-scale quantum computers that could break widely used public-key schemes.

This project proposes a privacy-first corporate messaging platform that addresses these risks. Membership authentication will be performed using Zero-Knowledge Proofs (ZKPs), enabling employees to prove organisational affiliation without revealing personal identifiers. To provide verifiable, tamper-evident registration and authentication records for audit and SSO workflows, compact attestations (cryptographic commitments or transaction identifiers) of ZKP registrations will be recorded on a permissioned blockchain explicitly limited to registration/authentication artifacts only. All message exchange will remain off-chain and protected by Post-Quantum Cryptography (PQC) or hybrid PQC/classical primitives to ensure message confidentiality both today and after the advent of quantum adversaries.

By separating responsibilities blockchain for registration/auth attestations only, ZKP for identity-preserving membership proof, and PQC for durable end-to-end encryption the system aims to balance privacy, auditability, and long-term security. The design emphasises minimising stored identifiers and metadata, preventing messages or message metadata from being written to any ledger, and implementing short-lived attestation semantics (TTL/revocation) to mitigate permanence and linkability concerns. The prototype will include client-side ZKP generation, a permissioned-ledger attestation service for registration/auth, and off-chain PQC messaging with crypto-agile interfaces to allow future algorithm upgrades.

This work fills a practical gap in the literature and in organisational practice: while ZKPs, PQC, and blockchain identity concepts have been explored independently, there is limited published work that integrates ZKP-based, identifier-free authentication with permissioned on-chain attestations (registration/auth only) and PQC-protected off-chain messaging for corporate internal use. The project will design, implement, and evaluate a prototype and produce empirical measurements (functional correctness, authentication latency, proof sizes, client resource usage, and privacy/linkability analysis) to demonstrate feasibility and to guide real-world adoption decisions.

2. Problem Statement

- **Reliance on personal identifiers and metadata leakage**

  Many modern messaging services require phone numbers, emails or other persistent identifiers for onboarding and account recovery. Even when message content is end-to-end encrypted, these identifiers plus associated metadata (who talks to whom, timestamps, contact graphs) enable profiling and can be as privacy-sensitive as message content itself a serious issue for corporate internal communications.

  Evidence: a formal analysis of WhatsApp shows that E2EE protects content but that metadata can reveal social graphs and behavioural patterns; the authors conclude that encrypting payloads alone does not ensure privacy. Recent product changes that expand metadata use (e.g., new ad features tied to user activity) have renewed concerns about metadata handling.

- **Long-term confidentiality risk from quantum computing ("harvest now, decrypt later")**

  Today's common public-key systems (RSA, ECC) are theoretically vulnerable to sufficiently capable quantum computers. That creates a "harvest now decrypt later" threat: adversaries can record encrypted traffic today and decrypt it in the future once quantum capabilities are available, placing archived corporate communications at risk. Organisations therefore must plan migration paths to quantum-resistant primitives.

  Evidence: NIST's PQC program and guidance explicitly advise preparing to migrate key-establishment schemes to quantum-resistant algorithms to mitigate harvest-now risks; NIST has recently finalised candidate PQC algorithms and published transition guidance (including an (Interagency Report) IR on migration planning).

3. Objective

1. **To study the current landscape of secure messaging and authentication**
   - Analyse commercial and academic messaging systems, identity providers, and federated architectures; review peer-reviewed literature and industry standards (e.g., NIST PQC guidance). Particular attention will be given to confidentiality risks from personal identifiers and metadata, the feasibility and trade-offs of PQC for messaging, and design options for on-chain registration/authentication attestations (full proof vs commitment/hash vs tx ID), including privacy and legal/retention implications.

2. **To develop a confidentiality-focused messaging platform using ZKP, PQC and blockchain attestations (registration/auth only)**
   - Design and implement a prototype in which user registration and ZKP-based membership attestations are recorded on a permissioned blockchain as compact, non-identifying commitments or transaction references; authentication validates clients against these attestations and issues short-lived JWTs for SSO. All message payloads remain off-chain and are protected by selected PQC primitives (or hybrid PQC/classical schemes) to ensure long-term confidentiality.

3. **To test and evaluate the developed prototype**
   - Validate functional correctness of the ZKP registration/auth flow and PQC messaging; perform security assessments (threat modelling, linkability/privacy analysis, cryptographic misuse checks, and penetration testing); and benchmark key performance metrics (authentication latency — proof generation + on-chain commit/confirmation, PQC handshake latency, CPU/memory usage, message size overhead, and ledger storage growth) against a traditional E2EE baseline to quantify trade-offs and guide optimisation.

4. Scope

1. Target Users: Employees and IT/security staff in corporate organisations

2. System Functions
   - Registration: ZKP-based registration where compact attestations (commitments/hashes or tx IDs) are recorded on a permissioned blockchain.
   - Authentication: Membership verification at login by validating client proofs against on-chain attestations; issuance of short-lived JWTs referencing attestation tx IDs.
   - Messaging: One-to-one and group messaging performed off-chain, protected by PQC (or hybrid) end-to-end encryption. No message content or message metadata is written to the ledger.

3. Platform Used
   - Programming Languages & Frameworks: JavaScript (Node.js, React.js), Python (for cryptographic modules)
   - Blockchain Framework: Hyperledger Fabric (for ZKP-based registration & authentication)
   - Cryptography Libraries: liboqs (Open Quantum Safe), snarkjs (ZKP)
   - Database: MongoDB (distributed deployment)
   - Server Infrastructure: Docker containers on distributed/fault-tolerant cloud instances
   - Frontend: React.js web application
   - Backend: Node.js with Express
   - Development Tools: Visual Studio Code, Postman, Git

5. Significance of the Project

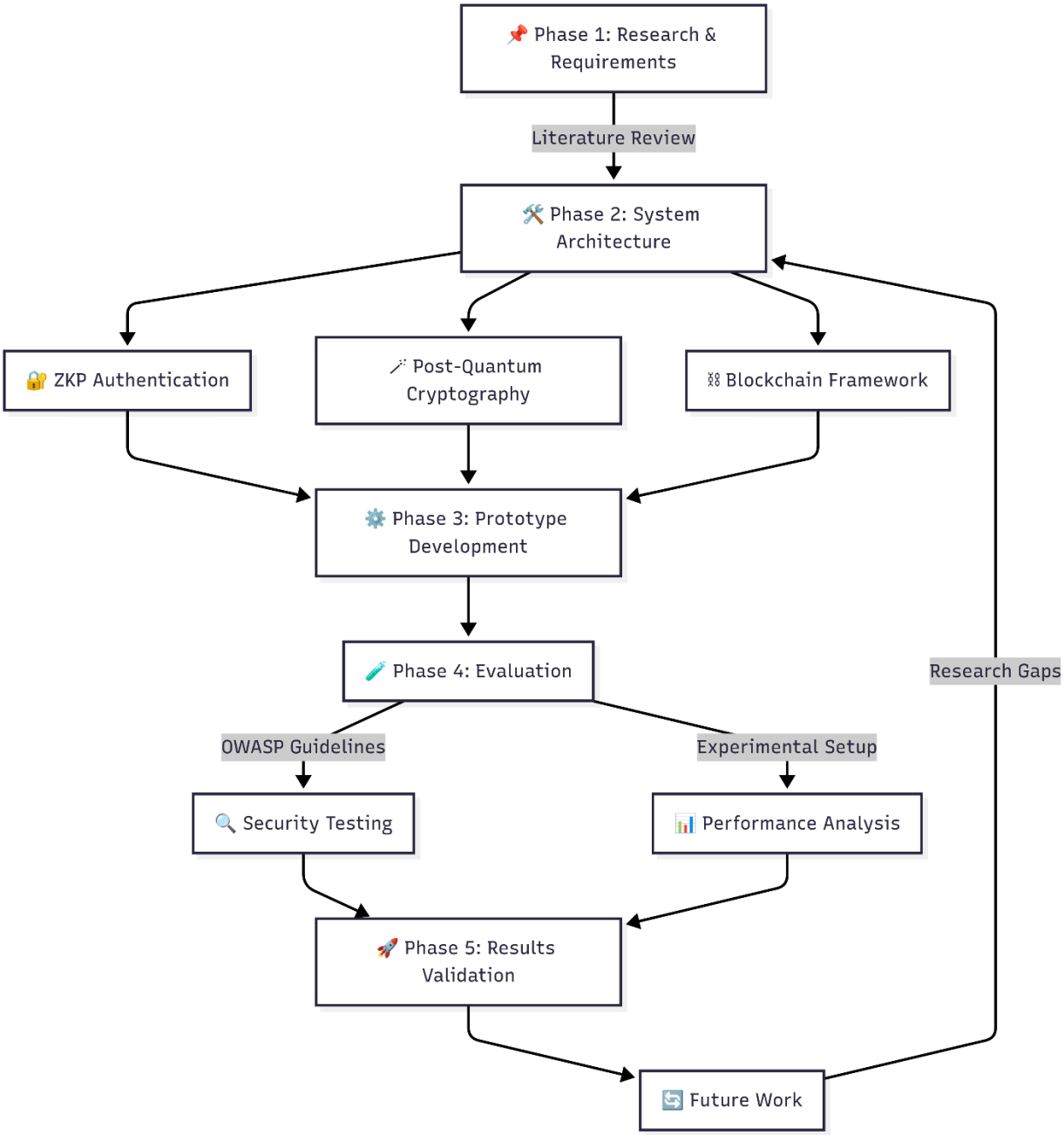
This project equips corporate organisations with a privacy-centric internal messaging solution that registers and verifies membership via Zero-Knowledge Proofs anchored as compact attestations on a permissioned blockchain (registration/auth only), while all message content remains off-chain and is protected using post-quantum cryptography — thereby reducing identity exposure, strengthening long-term message confidentiality, enabling auditable SSO and compliance evidence, and providing empirical data to guide secure deployment choices.

6. Literature Review

No	Citation	Aim	Key findings	Relevance to project
1	Mohan Kumar Gajula & Arunkumar Akuthota — *Algorithms Built to Prevent Future Quantum Attacks: Post-Quantum Cryptography…*	Survey PQC families and assess readiness.	Examines lattice/hash/code/multivariate/isogeny families; trade-offs: security vs key/ciphertext sizes; recommends hybrid strategies.	Guides PQC primitive selection and performance/security trade-offs.
2	Abdullah Aydeger et al. — *Towards a Quantum-Resilient Future: Strategies for Transitioning to PQC.*	Operational transition framework for PQC.	Recommends phased adoption (identify/protect/detect/respond/recover), hybrid deployments and NIST alignment.	Roadmap for integrating PQC into messaging stacks and prototype→production planning.
3	Saurav Bhattacharya et al. — *Enhancing Digital Privacy: The Application of Zero-Knowledge Proofs in Authentication Systems.*	Review ZKP constructions for authentication.	ZKP variants (zk-SNARKs, zk-STARKs, NIZKs) are promising; practical costs (proof size/time, trusted setup) are concerns.	Directly informs choice and optimisation of membership proof schemes.

4	Alexandr Silonosov & Lawrence Henesey — *Towards cryptographic agility manifesto in E2EE systems…*	Advocate crypto-agility and consumer metrics.	Calls for modular algorithms, migration paths, usable APIs and operational measures.	Supports a modular, swappable cryptographic architecture in the prototype.
5	Nidhi Rastogi & James Hendler — *WhatsApp security and role of metadata in preserving privacy.*	Analyse WhatsApp E2EE and metadata risks.	Shows that metadata (phone numbers, contact graphs, timestamps) undermines privacy even when payloads are encrypted.	Justifies avoiding personal identifiers and minimising metadata in onboarding.
6	Jiahui Xiang et al. — *Secure Blockchain-based Single Sign-On with Zero-Knowledge Proof Authentication* (GIIS 2025) *(user-provided)*	Propose blockchain as IdP and integrate ZKP into SSO; evaluate resource trade-offs (IoMT).	Demonstrates a permissioned blockchain + ZKP SSO prototype; suggests offloading and one-time read strategies; provides RAM/CPU/latency/network benchmarks.	Serves as a practical blueprint for storing ZKP attestations on a permissioned ledger (registration/auth only); informs TTL/revocation and resource-optimisation choices. *(user text)*

7. Methodology



7.1 Development Model

This project adopts the **Agile Software Development Model** with iterative sprints. Agile is chosen due to its flexibility, adaptability to requirement changes, and suitability for research-driven prototypes involving advanced cryptographic techniques.

Phases:

1. **Planning & Requirement Analysis**
    - Define functional and non-functional requirements based on literature review and industry needs.
    - Identify ZKP authentication methods, PQC algorithms, and blockchain integration scope.
2. **System Design**
    - Create high-level architecture diagrams for client, backend, blockchain, and database components.
    - Select cryptographic libraries (e.g., liboqs, snarkjs) and blockchain framework (Hyperledger Fabric).
3. **Implementation**
    - Develop the frontend (React.js) and backend (Node.js + Express).
    - Implement ZKP-based authentication on blockchain and PQC-based E2EE messaging.
4. **Testing & Evaluation**
    - Perform unit, integration, and functional testing.
    - Conduct performance benchmarking and security testing (threat modelling, penetration testing).
5. **Deployment & Review**
    - Deploy prototype on distributed cloud infrastructure.
    - Gather feedback from simulated organisational use cases.

7.2 Estimated Budget

Item	Specification / License Type	Estimated Cost (MYR)
Laptop (development)	Intel i7, 16GB RAM, 512GB SSD	3,800 (Freeware)
Cloud VM instances (3 months)	3 nodes, 4 vCPU, 8GB RAM each	1,200
Domain & SSL Certificate	1 year	200
Development Tools & IDEs	Open-source (VS Code, Docker)	0
Blockchain Framework	Hyperledger Fabric (open-source)	0
Cryptography Libraries	Open-source (liboqs, snarkjs)	0
Testing Tools	OWASP ZAP, JMeter (open-source)	0
Total		1400

Conclusion

This project aims to develop a secure corporate communication platform that combines Zero-Knowledge Proof (ZKP) authentication, Post-Quantum Cryptography (PQC) encryption, and blockchain-based registration to protect user privacy, ensure long-term data confidentiality, and eliminate single points of failure. By addressing current issues such as reliance on personal identifiers, vulnerability to quantum attacks, and centralised system weaknesses, the proposed solution will provide organisations with a reliable, privacy-first, and future-proof messaging system tailored for sensitive internal communications.

References

[1] M. K. Gajula and A. Akuthota, "Algorithms Built to Prevent Future Quantum Attacks: Post-Quantum Cryptography in Preparation for Quantum Computing Threats," *2023 IEEE International Conference on Quantum Computing and Engineering (QCE)*, Bellevue, WA, USA, 2023, pp. 256-263.

[2] A. Aydeger, J. M. Walker, and L. E. Oliveira, "Towards a Quantum-Resilient Future: Strategies for Transitioning to Post-Quantum Cryptography," *IEEE Access*, vol. 10, pp. 60123–60136, 2022.

[3] S. Bhattacharya, J. Jedlicka, and E. S. Grant, "Enhancing Digital Privacy: The Application of Zero-Knowledge Proofs in Authentication Systems," in *Proceedings of the 2022 International Conference on Privacy, Security, and Trust (PST)*, Copenhagen, Denmark, Aug. 2022, pp. 45–54.

[4] A. Silonosov and L. Henesey, "Towards cryptographic agility manifesto in end-to-end encryption systems: a position paper from the perspective of crypto-consumers," in *Proceedings of the 2021 International Conference on Information Security and Privacy (ICISP)*, Dec. 2021, pp. 11–20.

[5] N. Rastogi and J. Hendler, "WhatsApp security and role of metadata in preserving privacy," *Journal of Cybersecurity and Privacy*, vol. 1, no. 1, pp. 79–99, Mar. 2021.